UT1. Gestión de Acceso a la base de datos

RA 3. Implanta métodos de control de acceso utilizando asistentes, herramientas gráficas y comandos del lenguaje del sistema gestor

Gestión de cuentas de Usuario

.-> Seguridad (El Principio del Mínimo Privilegio): Debemos asegurarnos de que cada usuario (ya sea una persona o una aplicación) solo tenga acceso a **lo estrictamente necesario** para realizar su trabajo.

.-> **Responsabilidad y Auditoría:** Si ocurre un error o una manipulación indebida. Dentro de la base de datos, cada acción queda registrada bajo el usuario que la ejecutó.

.> Rendimiento y Control de Recursos: Podemos limitar cuántas conexiones puede hacer un usuario o desde dónde puede conectarse, ayudando a controlar la carga del servidor y a prevenir ataques de denegación de servicio.

Gestión de cuentas de Usuario

1. CREAR UN NUEVO USUARIO

Sintaxis: CREATE USER 'nombre_usuario'@'host' IDENTIFIED BY 'contraseña';

El 'host' define desde dónde se puede conectar el usuario:
'localhost' (solo desde el propio servidor) o '%' (desde cualquier lugar).

EJEMPLOS

```
CREATE USER 'desarrollador_web'@'localhost' IDENTIFIED BY 'PasswordSegura01';
CREATE USER 'analista_bi'@'%' IDENTIFIED BY 'ReporteDatos456';
```

(% es un comodín para indicar cualquier parte, permite que este usuario se conecte desde cualquier dirección IP externa o computadora.).

2. VER LOS USUARIOS CREADOS

Esta sentencia consulta la tabla 'user' dentro de la base de datos 'mysql'.

```
SELECT User, Host FROM mysql.user;
```

(Host es para especificar desde dónde tiene permitido conectarse el usuario).

3. Otorgar TODOS los privilegios en TODAS las bases de datos y tablas (*)

SOLO debe usarse para administradores o desarrollo local.
WITH GRANT OPTION permite al usuario conceder los permisos a otros (¡usar con precaución!).

```
GRANT ALL PRIVILEGES
ON *.* TO 'admin_local'@'localhost'
IDENTIFIED BY 'RootPass789'
WITH GRANT OPTION;
```

```
1. GRANT ALL PRIVILEGES   ──► Le da TODOS los permisos posibles (SELECT, INSERT,
                              DROP, ALTER, CREATE, SUPER, etc.).

2. ON *.*                 ──► Ámbito global: Primera '*' = TODAS las bases de datos
                                             Segunda '*' = TODAS las tablas.

3. TO 'admin_local'...    ──► Asigna todo esto al usuario 'admin_local' que solo
                              puede conectar desde la propia máquina ('localhost').

4. WITH GRANT OPTION;     ──► ¡EL PODER DE DELEGAR! Le otorga el "llavero maestro":
                              este usuario podrá hacer GRANT de sus propios
                              permisos a terceras personas
```

4. APLICAR LOS CAMBIOS DE PRIVILEGIOS

Es vital para que MySQL recargue los permisos y los cambios surtan efecto.

```
FLUSH PRIVILEGES;
```

5. REVOCAR PRIVILEGIOS (Quitar permisos)

Sentencia clave: REVOKE privilegios ON base_datos.tabla FROM 'usuario'@'host';

Quitarle al desarrollador la capacidad de BORRAR (DELETE) en la tabla 'productos'.

```
REVOKE DELETE
ON tienda_online.productos
FROM 'desarrollador_web'@'localhost';
```

LISTA DE PRIVILEGIOS SOBRE LAS TABLAS

Privilegio	Qué Permite Hacer	Nivel Típico de Uso
SELECT	Leer o consultar datos de una tabla (o vista).	El más común. Necesario para cualquier usuario que deba ver datos.
INSERT	Añadir nuevas filas (registros) a una tabla.	Usuarios de aplicaciones web (ej. registrar nuevos clientes).
UPDATE	Modificar datos en filas existentes de una tabla.	Usuarios que editan información (ej. cambiar una dirección).
DELETE	Eliminar filas (registros) de una tabla.	Controlado. Solo para usuarios o procesos que lo requieran explícitamente.

LISTA DE PRIVILEGIOS SOBRE LA ESTRUCTURA DE LAS BASE DE DATOS: DDL

Privilegio	Qué Permite Hacer	Nivel Típico de Uso
CREATE	Crear nuevas bases de datos, tablas o índices.	Desarrolladores y administradores.
ALTER	Modificar la estructura de una tabla (ej. añadir o borrar una columna).	Desarrolladores y administradores.
DROP	Eliminar por completo bases de datos, tablas o vistas.	Solo administradores. Es un permiso muy peligroso.
INDEX	Crear o eliminar índices en las tablas.	Desarrolladores (para optimización).
CREATE VIEW	Crear nuevas vistas (tablas virtuales).	Desarrolladores y administradores.

LISTA DE PRIVILEGIOS SOBRE EL PROPIO SERVIDOR Y OTROS USUARIOS

Privilegio	Qué Permite Hacer	Nivel Típico de Uso
GRANT OPTION	Permite al usuario que lo posee otorgar a otros usuarios los privilegios que él tiene.	Solo administradores de confianza.
SUPER	Permite ejecutar comandos de administración críticos (ej. apagar el servidor, manipular la configuración global).	Solo el usuario root o administradores con acceso a bajo nivel.
PROCESS	Ver todos los procesos que se están ejecutando en el servidor (incluyendo los de otros usuarios).	Administradores (para tareas de monitorización).
RELOAD	Ejecutar la sentencia FLUSH PRIVILEGES o recargar logs y cachés internos.	Administradores (para aplicar cambios de configuración o permisos).

6. MODIFICAR LA CONTRASEÑA DE UN USUARIO EXISTENTE

Esto es fundamental por seguridad y políticas de rotación de contraseñas.

```
ALTER USER 'desarrollador_web'@'localhost'
IDENTIFIED BY 'NuevaPasswordSegura2025';
```

7. ELIMINAR UN USUARIO

Usar con mucha cautela! Esto elimina el usuario y sus permisos permanentemente.

```
DROP USER 'usuario_a_eliminar'@'host';
```

Ejemplo:

```
DROP USER 'analista_bi'@'%';
FLUSH PRIVILEGES;
```

6. MODIFICAR LA CONTRASEÑA DE UN USUARIO EXISTENTE

Esto es fundamental por seguridad y políticas de rotación de contraseñas.

```
ALTER USER 'desarrollador_web'@'localhost'
IDENTIFIED BY 'NuevaPasswordSegura2025';
```

7. ELIMINAR UN USUARIO

Usar con mucha cautela! Esto elimina el usuario y sus permisos permanentemente.

```
DROP USER 'usuario_a_eliminar'@'host';
```

Ejemplo:

```
DROP USER 'analista_bi'@'%';
FLUSH PRIVILEGES;
```

Ejercicio:
Crear una base de datos, gestión_stock. La tabla es la siguiente, inventario:

Campo en productos	Tipo de Dato	Sensibilidad
codigo_producto	VARCHAR	Baja
nombre	VARCHAR	Media
stock_actual	INT	Alta (Solo visible para Almacén/Gerencia)
precio_venta	DECIMAL	Media
proveedor	VARCHAR	Baja

Crear una Vista llamada **vista_catalogo_publico**.

Esta vista, muestra todos los productos del catálogo, salvo la columna de stock_actual.

Es decir, la vista deberá tener las siguientes columnas:
codigo_producto,
nombre,
precio_venta
proveedor

Una vez creada la vista, vas a crear los siguientes usuarios con las siguientes restricciones.

Nombre usuario	IP	Requisitos de Privilegio
comercial_ext	% (Cualquier IP)	Solo puede realizar consultas (SELECT) sobre la vista vista_catalogo_publico. No debe poder hacer ninguna otra tarea ni ver la tabla original.
almacen_op	Localhost	Debe poder realizar INSERT, UPDATE y DELETE en la tabla original productos. Su trabajo es manipular los datos, pero no la estructura.
analista_bi	%(Cualquier IP)	Debe poder crear (CREATE) nuevas tablas o vistas en la BD gestion_stock (para guardar sus informes temporales) y realizar SELECT en la tabla productos. No debe tener acceso a la vista vista_catalogo_publico.

Una vez creados los usuarios, y asignados los privilegios, debéis realizar lo siguiente:

- El usuario 'comercial_ext' intenta hacer un SELECT a la tabla productos. ¿Qué error recibe?

- El usuario 'almacen_op' intenta hacer un DROP TABLE en productos. ¿Qué error recibe?

- El usuario 'analista_bi' intenta hacer un SELECT a vista_catalogo_publico. ¿Puede hacerlo? (Debería fallar).

Qué es un Rol

Un **rol** es un **conjunto de privilegios** que se pueden asignar a uno o varios usuarios.
Se puede entender como un “perfil de permisos” predefinido, que agrupa privilegios comunes.

Por ejemplo:

- El rol **desarrollador** puede tener permisos de lectura y escritura sobre las tablas de una base de datos de desarrollo.
- El rol **auditor** puede tener solo privilegios de lectura.

Ventajas:

- Si un privilegio cambia, solo hace falta modificarlo en el rol, y **automáticamente afecta a todos los usuarios que lo tienen asignado**.
- **Simplifican** la administración de privilegios: se agrupan y aplican en bloque.
- **Evitan errores** al conceder o revocar privilegios usuario por usuario.
- **Aumentan** la **coherencia**: todos los usuarios con el mismo rol tienen exactamente los mismos permisos.
- **Facilitan la gestión de equipos**: se pueden definir roles por puesto o función (por ejemplo, rol_admin, rol_lectura, rol_invitado).
- **Permiten jerarquía**: un rol puede incluir otros roles.

Sintaxis para crear y usar roles

- **Crear ROLE**

```
CREATE ROLE 'nombre_rol';

CREATE ROLE 'rol_desarrollador', 'rol_auditor';
```

- **Asignar privilegios a un ROLE**

```
GRANT SELECT, INSERT, UPDATE, DELETE ON basededatos.tablas TO 'rol_desarrollador';

GRANT SELECT, INSERT, UPDATE, DELETE ON empresa.* TO 'rol_desarrollador';
```

- **Asignar un rol a un usuario**

```
GRANT ‘nombrerol' TO ‘usuario'@’Ip';

GRANT 'rol_desarrollador' TO 'ana'@'localhost';
```

Sintaxis para crear y usar roles

- **Activar un rol para un usuario**

```
SET  ROLE 'nombre_rol';
```

```
SET ROLE 'rol_desarrollador';
```

- **Activar automáticamente al iniciar sesión:**

```
SET DEFAULT ROLE ALL TO 'usuario'@'ip';
```

```
SET DEFAULT ROLE ALL TO 'ana'@'localhost';
```

- **Revocar un rol de un usuario**

```
REVOKE 'rol_desarrollador' FROM 'usuario'@'ip';
```

```
REVOKE 'rol_desarrollador' FROM 'ana'@'localhost';
```

- **Ver roles y asignaciones**

```
SHOW GRANTS FOR ‘nombre_rol';
SHOW GRANTS FOR 'usuario'@'ip';
```

```
SHOW GRANTS FOR 'rol_desarrollador';
SHOW GRANTS FOR 'ana'@'localhost';
```

Qué es un Perfil

Un **perfil** (en otros SGBD como Oracle o PostgreSQL) define **parámetros de seguridad y recursos** asociados a un usuario, como:

- Límites de tiempo de sesión.
- Número máximo de intentos de conexión fallidos.
- Políticas de caducidad de contraseña.
- Restricciones de consumo de CPU, memoria, etc.

📘 En **MySQL**, la gestión de perfiles como tal **no existe** con ese nombre, pero **sí existen políticas de contraseña y seguridad** que cumplen una función similar, mediante el **plugin de validación de contraseñas** y el **sistema de políticas de expiración y complejidad**.

```
ALTER USER 'ana'@'localhost'
IDENTIFIED BY 'ContraseñaSegura123!'
PASSWORD EXPIRE INTERVAL 90 DAY;
```

Característica	Rol	Perfil (política de usuario)
Función principal	Agrupar y gestionar **privilegios**	Controlar **recursos y seguridad de contraseñas**
Ámbito	Permisos sobre objetos (tablas, vistas, bases de datos)	Parámetros de usuario (contraseña, expiración, sesiones)
Gestión en MySQL	Disponible desde MySQL 8.0	Se simula mediante ALTER USER, PASSWORD POLICY
Ejemplo típico	CREATE ROLE rol_lectura;	ALTER USER 'juan' PASSWORD EXPIRE;

Ejemplo práctico.

1.- Revoca los privilegios a los usuarios que has creado antes.

2.- Crea roles comercial, operador, diseñador.

3.- Asigna los privilegios.

4.- Asigna a los usuarios a esos roles

5.- Vuelve a realizar las tareas de la diapositiva 13

Rol del Usuario	Requisitos de Privilegio	
Comercial	Solo puede realizar consultas (SELECT) sobre la vista vista_catalogo_publico. No debe poder hacer ninguna otra tarea ni ver la tabla original.	comercial_ext
Operador	Debe poder realizar INSERT, UPDATE y DELETE en la tabla original productos. Su trabajo es manipular los datos, pero no la estructura.	almacen_op
Diseñador	Debe poder crear (CREATE) nuevas tablas o vistas en la BD gestion_stock (para guardar sus informes temporales) y realizar SELECT en la tabla productos. No debe tener acceso a la vista vista_catalogo_publico.	analista_bi